IT Security Policy

Kestrel Ridge Technologies Ltd.

Document ID	Version	Effective date	Policy owner	Next review
IT-POL-001	5.0	1 January 2026	Chief Information Security Officer	31 December 2026

1. Purpose and Scope

1.1 This policy protects the Company's information, systems and customers from loss, misuse and cyber attacks.

1.2 It applies to all employees, interns, contractors and visitors who use Company devices, networks, accounts or data, whether in the office or working remotely.

2. Roles and Responsibilities

- **IT Security team:** owns this policy, monitors systems and leads incident response.
- **IT Service Desk:** first point of contact for security issues; phone extension 4357 or servicedesk@kestrelridge.example.
- **Managers:** ensure their teams complete training and follow this policy.
- **All users:** protect their accounts and devices and report incidents immediately.

3. Acceptable Use

3.1 Company systems are provided for business purposes. Limited personal use is allowed if it does not affect work, does not break any law and does not create a security risk.

3.2 Users must not share accounts, bypass security controls, install unapproved software, or access data they do not need for their role.

4. Passwords and Authentication

4.1 Passwords must be unique for each system and must never be shared or written down. Users should use the Company-approved password manager.

Account type	Minimum length	Multi-factor authentication (MFA)	Password change
Standard user account	14 characters	Required for email, VPN and HRConnect	Only if compromise is suspected
Privileged / admin account	20 characters	Required for every login	Every 90 days
Service account	32 characters (random)	Not applicable	Every 180 days, managed by IT

4.2 An account is locked for 15 minutes after 5 failed login attempts.

4.3 MFA codes or approval prompts must never be shared with anyone, including people who claim to be from IT.

5. Data Classification and Handling

5.1 All Company information must be classified into one of four levels and handled as shown below.

Level	Examples	Handling rules
Public	Marketing website content, published press releases	No restrictions.
Internal	Policies, internal announcements, org charts	Share only with employees and approved contractors.
Confidential	Customer contracts, financial reports, source code	Encrypt when sent outside the Company; share on a need-to-know basis.
Restricted	Employee salary and health data, passwords, customer personal data	Encrypted at all times; never stored on USB drives or personal devices; access logged.

5.2 If the classification of a document is unclear, treat it as Confidential until the information owner confirms.

6. Devices

6.1 Company laptops are protected with full-disk encryption (BitLocker) and endpoint protection software. Users must not disable these controls.

6.2 Screens must lock automatically after 5 minutes of inactivity. Users must lock their screen (Windows key + L) whenever they leave their device.

6.3 Personal devices (BYOD) may be used only for Company email and chat, and only after enrolment in the Company mobile device management (MDM) system.

6.4 USB storage devices are blocked by default. An exception requires a Service Desk ticket approved by the IT Security team and is valid for a maximum of 30 days.

7. Software and Updates

7.1 Software may only be installed from the Company Software Center. Requests for new software are raised through the Service Desk and reviewed by IT Security.

7.2 Security updates must be installed within 14 days of release. Critical security updates must be installed within 72 hours. Devices that are not updated may be blocked from the network.

8. Email and Phishing

8.1 Users must report suspicious emails using the "Report Phishing" button in Outlook, or by forwarding them to security@kestrelridge.example. Do not click links or open attachments in suspicious emails.

8.2 Company email must not be auto-forwarded to personal email accounts.

8.3 The IT team will never ask for your password by email, phone or chat.

9. Remote Work and Networks

9.1 The Company VPN must be used when working on public or hotel Wi-Fi networks.

9.2 Users working from home must change the default password on their home router and use WPA2 or WPA3 encryption.

9.3 Confidential and Restricted information must not be viewed in public places where screens can be seen by others.

10. Use of AI Tools

10.1 Only AI tools approved by IT Security may be used for Company work. The list of approved tools is published on the intranet.

10.2 Confidential or Restricted information must never be entered into public AI tools or chatbots that are not on the approved list.

10.3 Output from AI tools must be reviewed by a person before it is shared with customers.

11. Security Incident Reporting

11.1 Any suspected security incident must be reported to the IT Service Desk (extension 4357) within 1 hour of discovery.

11.2 Lost or stolen Company devices must be reported within 2 hours so the device can be remotely locked and wiped.

Severity	Example	IT Security response time
Critical	Ransomware, confirmed data breach	Within 15 minutes, 24x7
High	Compromised account, lost laptop	Within 1 hour
Medium	Malware detected and blocked, phishing email clicked	Within 4 business hours
Low	Policy question, suspicious email not clicked	Within 2 business days

12. Physical Security

12.1 Employees must wear their ID badge visibly at all times inside Company offices and must not let anyone "tailgate" through a secure door.

12.2 Visitors must sign in at reception, wear a visitor badge and be escorted by their host at all times. Visitors may not connect to the internal network; they may use the Guest Wi-Fi only.

12.3 Clean desk rule: Confidential and Restricted papers must be locked away at the end of the day, and printouts must be collected from printers immediately.

13. Backup and Data Retention

13.1 Work files must be saved in the Company OneDrive or approved shared drives, which are backed up every day. Files stored only on a laptop's local disk are not backed up.

Data type	Retention period	Disposal method
Email	3 years	Automatic deletion
Financial and tax records	8 years	Secure deletion by Finance
Employee personnel files	7 years after the employee leaves	Secure deletion by HR
System and security logs	1 year	Automatic deletion
Paper documents (Confidential or Restricted)	As per the record type above	Cross-cut shredding or locked shred bins

13.2 Old laptops, phones and hard drives must be returned to IT for certified data wiping. They must never be sold, given away or thrown away by employees.

14. Third-Party and Vendor Access

14.1 Vendors who need access to Company systems must sign a non-disclosure agreement and complete a security assessment before access is granted.

14.2 Vendor accounts are created with an expiry date of no more than 90 days and are reviewed by the sponsoring manager before renewal.

15. Training and Compliance

15.1 New joiners must complete security awareness training within 30 days of joining. All users must complete refresher training every year.

15.2 The IT Security team runs simulated phishing tests. Users who fail a test are assigned additional training.

15.3 Breaches of this policy may result in disciplinary action, up to and including termination of employment.

Revision history

Version	Date	Change
4.0	1 January 2025	Introduced MFA for all standard accounts; USB storage blocked.
4.1	1 June 2025	Added data retention schedule (Section 13).
5.0	1 January 2026	Added Use of AI Tools (Section 10); removed 90-day password change for standard users.